Monthly Intelligence Dispatch

July 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Twitter suffered the biggest attack in its history.
- CERT-GIB issued a warning about a malicious mailout purporting to be sent by Group-IB.
- Researchers at vpnMentor discovered publicly available data on more than 20 million users of free VPN solutions.
- The North Korean APT group Lazarus has been actively attacking users through fake cryptocurrency trading apps.
- CERT-GIB detected a mailout, in which threat actors distributed RTM, a banking Trojan, posing as Russia's Federal Bailiffs Service.
- The database of Citrix Systems, Inc., a large US IT company, was put up for sale.
- On July 7, 2020, the US Department of Justice announced an indictment charging a citizen of Kazakhstan, Andrey Turchin (aka Fxmsp), with various cybercrimes.

Twitter

In July, **Twitter** suffered the biggest attack in its history. One after another, the official accounts of celebrities, politicians, and business people, such as **Elon Musk**, **Bill Gates**, **Barak Obama**, **Joe Biden**, and **Kanye West**, posted strange tweets offering an opportunity to make money by sending $1,000 worth of Bitcoin to a specific crypto wallet to get twice as much in return. In a couple of hours, the fraudsters received more than $100,000. The fake messages were deleted and Twitter began an investigation. According to one version, the hackers gained access to one of Twitter's moderator or administrator accounts, including internal systems and tools, which helped the attackers bypass two-factor authentication and access multiple user accounts without knowing logins and passwords. Another unobvious aspect of the hack is that the attackers had full access to compromised accounts, including Direct Messages. Twitter said that they considered the hack a "coordinated social engineering attack," which targeted certain Twitter staffers with access to internal systems and tools. It is already clear that the incident entails enormous reputational and, as a result, financial losses for Twitter.

Garmin	In July, the company Garmin fell victim to ransomware. The attack started in the company's Taiwan-based department and Garmin had to suspend some of its services. In addition to GPS-based wearables, the incident affected flyGarmin and Garmin Pilot, which are solutions that support the company's line of navigational equipment for the aviation industry. The threat actors demanded a ransom of ten million dollars to decrypt files. Bleeping Computer said that WastedLocker operators (Evil Corp group) were behind the attack. In June 2020, analysts estimated that no fewer than three dozen US organizations and companies were affected by WastedLocker attacks, with one of them facing a ten-million-dollar ransom demand.
REvil	In July, the REvil ransomware was used in an attack on Telecom Argentina, one of Argentina's biggest Internet service providers (ISPs). The virus infected about 18,000 computers and its operators demanded that the company pay a ransom of $7.5 million. ZDNet says the attackers obtained domain administrator privileges, which is why the ransomware quickly spread across the network. Surprisingly, the incident did not cause Internet connection problems for the ISP's customers, nor did it affect telephony or cable TV services.

groupIB_pv@.	CERT-GIB detected malicious mailouts to Russian companies and government agencies. In some of the emails, the address featured Group-IB's name: groupIB_pv@. The dangerous emails were identified and neutralized by Group-IB's Threat Detection System (TDS), which is designed to prevent advanced cyber threats. The emails were written by a "business security specialist" (no such person is working at Group-IB of course) and mentioned a meeting with Group-IB staff on July 3, specifying that all employees were required to attend it. The "security specialist" asked recipients to follow a link, fill in a form, and read materials related to the meeting. The link in the email downloads an archive, which contains a malicious file called "Zayavl_Kontseptsiya_bezopasnosti.doc" [Security concept form]. This is an RTF document disguised as a DOC file, which once launched loads an HTML page containing a JS script. The script exploits a vulnerability, which results in the launch of a backdoor and access to an infected machine. CERT-GIB promptly warned TDS Polygon customers about this threat.
RTM	On July 28, **CERT-GIB** analysts detected a mailout, in which threat actors distributed **RTM** (a banking Trojan designed to steal money from remote banking service systems) by posing as Russia's Federal Bailiffs Service. In addition, the Trojan had spyware functionality. The recipients included Russian government agencies, banks, and research and development enterprises. Posing as an employee of the Russian Federal Bailiffs Service, the threat actors asked email recipients to fill in documents (downloaded using a link they included), print them out, and submit them to tax authorities. The threat actors' goal was to trick the recipients into downloading a malicious attachment and launch it. The attack was detected by TDS Polygon. Emails that targeted Group-IB's customers were identified as malicious and blocked.

drumrlu	In June 2020, Group-IB's monitoring of underground forums revealed a new seller of access to corporate networks, drumrlu. The threat actor has a total of 11 instances of access to various IT companies and data centers (France, Italy, and Switzerland), a police department (UAE), the Ministry of Foreign Affairs of Egypt, an oil company (UAE), and an insurance company (Thailand). The seller registered their first forum accounts in May 2020 (on raidforums and hackforums). A month later, they created accounts on nulled and Exploit.in.
Citrix Systems	On June 12, a post appeared on xss.is advertising the sale of the customer database of Citrix Systems, Inc., a major US IT company. The database contains about two million records, including full names, phone numbers, and email addresses. The threat actor provided a screenshot as proof and asked $20,000 for the database. Based on the screenshot, the database, which is called citrix_leads_vivo, is in SQL format. Two days later, a forum moderator said that they had checked the database and officially allowed its sale through the forum's guarantor service.
VPN	Researchers at vpnMentor discovered publicly available data on more than 20 million users of free VPN solutions, namely **UFO VPN, Fast VPN, Free VPN, Super VPN, Flash VPN, Secure VPN, and Rabbit VPN**. An unprotected server hosted 1.2 TB of user data, including email addresses, clear-text passwords, phone models, and device IDs. In addition to data leaks, free VPN services are dangerous in that if a server is created and controlled by threat actors, they will be able to intercept all user traffic, redirect it to phishing websites, and collect unencrypted data, which is how passwords, email correspondence, and other information can be leaked. Secondly, there have been cases when malicious programs were disguised as VPN applications, e.g. spyware mimicking the VPN service of a well-known integrator.

Lazarus

The North Korean APT group **Lazarus** has been actively attacking users through fake cryptocurrency trading applications. To be more convincing and ensure better distribution, the hackers create websites and social media accounts for their platform. For instance, in June 2020, Group-IB observed malicious applications called Coin Go Trade, Kupay Wallet, and Dorusio Wallet, which were designed for both Windows and macOS. Lazarus's another new method was detected on a website for making purchases in the .ru domain zone: during Bitcoin payments, the recipient address was replaced and money was transferred to the threat actors. Lazarus's interest in Russia is likely based not only on self-interest but also on political factors, since Russia is actively advocating for a dialogue between North and South Korea.

3D Secure (3DS)

Since the start of the pandemic, Group-IB has seen a spike in fraud involving card-to-card transfers: between April and June this year, the number of such transactions rose more than sixfold. According to Group-IB, one bank records an average of 400–600 attempts of this type of fraud per month at the moment. The average transfer sum is over $95. Fraudsters lure users to phishing websites, where victims enter their payment details thinking that they are making a payment. This data is used by threat actors to access banks' P2P services to transfer money to their accounts.

Sberbank	Group-IB specialists discovered a post advertising the sale of Sberbank cards. The user TwentyZenix put up for sale Sberbank's credit, debit, and Business World-category cards. The seller mentioned that they had used the compromised cards to make purchases on Yandex.Eda, a food delivery service. They also said that the cards were related to aviation services and highlighted that balances on the Business World-category cards were $6,800 and upwards. The price of a Business World card is $45 ($40 if the buyer leaves a review on the forum); debit and credit cards are $15 and $20 each respectively. Minimum order quantity is one card. Payments are made through QIWI, a payment service.
Tinkoff	On July 15, Group-IB's Threat Intelligence system detected a phishing webpage that imitated the payment form of the service Tinkoff Insurance. Once it receives payment details, the phishing page sends that information to the threat actors' Telegram chat using a bot and arranges a payment to a card belonging to the threat actors.
MTS Bank	Group-IB specialists discovered a post advertising the sale of access to the corporate network of MTS Bank. Each instance of access includes network structure information, access to the domain admin, passwords for all network devices, passwords for password managers, etc. Group-IB's Threat Intelligence specialists contacted the seller and found out that the access had not been sold and was still on offer. It was RDP-type access. To gain it, the threat actor may have carried out a brute force attack through an open RDP port.

Zero-day vulnerabilities

In late July, the security expert **Neal Krawetz** published details about two zero-day vulnerabilities affecting Tor and Tor Browser. The specialist mentioned the first zero-day flaw in his blog on July 23, 2020, describing how companies and Internet service providers could block users from connecting to the Tor network by scanning network connections for "a distinct packet signature" that is unique to Tor traffic. Krawetz described the second vulnerability in a blog post on July 30, 2020. Like the first one, this flaw allows network operators to detect Tor traffic. However, while the first issue could be used to detect direct connections to the Tor network, the second one can be used to detect indirect connections that users make to Tor bridges. According to the researcher, he decided to publicly disclose the flaws because the Tor Project had repeatedly failed to fix vulnerabilities that he reported.

TriumphLoader

A user with the nickname **BelialDemon** made a post on Exploit.in about the sale of a new resident loader called TriumphLoader. **TriumphLoader** is made up of a 130-KB resident part and a 370-KB loader module. The author said that the loader was already being actively used. The price of a TriumphLoader license is $400 per month. The seller also put up for sale three copies of the TriumpLoader source code, $1,700 each.

Raccoon

A user with the nickname raccoonstealer made a post about renting out the Raccoon stealer (aka Legion, Mohazo, and Racealer). The malware supports cookie grabber, loader, and form grabber functionality and can obtain system information and other user data in all versions of Microsoft Windows.

Arrests and sentences

Fxmsp

On July 7, 2020, the US Department of Justice unsealed an indictment charging a citizen of Kazakhstan, Andrey Turchin, aka fxmsp, with various cybercrimes, announced US Attorney Brian T. Moran. On June 23, Group-IB released the analytical report *Fxmsp: "The invisible god of networks,"* which revealed the identity of the hacker behind the nickname Fxmsp, one of the most notorious and prolific sellers of access to corporate networks, who had been offering his services on underground networks for about three years. During that time, he compromised hundreds of companies in 44 countries. According to conservative estimates, he may have made $1.5 million.

Li Xiaoyu, Dong Jiazhi

The US Department of Justice published an indictment charging two nationals of China, Li Xiaoyu (李啸宇), 34, and Dong Jiazhi (董家志), 33, with hacking into the computer systems of hundreds of victim companies, governments, non-governmental organizations, and democratic and human rights activists within and outside the United States, including Hong Kong and China. Prosecutors believe the hackers engaged in data theft and worked both for personal profit and for Chinese state security bodies such as the Guangdong State Security Department (GSSD) and the Ministry of State Security (MSS). In their search for trade secrets, the hackers targeted high-tech companies, research centers, and government agencies in Australia, Belgium, Germany, Japan, Lithuania, the Netherlands, Spain, South Korea, Switzerland, and the United Kingdom for several years. More recently, their targets have been quite relevant, namely pharmaceutical and biotechnology companies developing COVID-19 vaccines, testing technology, and treatments.

Forecasts and warnings

- The bold but primitive attack on Twitter aimed at hijacking the accounts of the world's most powerful people could have led to the most unexpected consequences from the crashes of financial markets to military action between countries.
- Access to the corporate networks of international companies and government agencies sold by drumrlu could be used by ransomware operators for initial intrusion or by APT groups for cyber espionage.
- We recommend using trusted and paid VPN services only; an even better option would be to set up and use your own VPN.
- To prevent 3D Secure (3DS) fraud, Group-IB recommends that banks upgrade to 3DS 2.0, where the existing vulnerability has been patched. The problem can also be solved by using an additional authentication step in the form of CAPTCHA or technologies based on behavioral analysis, which would ensure page integrity control by collecting additional information about a given page, such as the domain, contents, forms, and elements.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com